

Acme Retail Inc. İçin Forensic Reconstruction Runbook

Senaryo

Acme Retail Inc., Huawei Cloud TR-Istanbul bölgesinde çalışan, 2.000 çalışanlı bir online giyim perakendecisidir. Salı günü saat 03:14 UTC'de izleme sistemleri alarm üretmeye başlar. Bu runbook, olayın ilk üç saatini yalnızca Huawei Cloud servisleri kullanarak yeniden yapılandırır.

Bu dokümanın amacı; her aşamada hangi Huawei Cloud servisinin sorgulanacağını, hangi filtre veya SQL sorgusunun kullanılacağını ve hangi kanıtların bulunmasının beklendiğini adım adım göstermektir.

Olay 1 — 03:14:22 UTC

prod-checkout-asg Üzerinde Cloud Eye CPU Alarmı

Durum

Cloud Eye alarm üretir: prod-checkout-asg auto-scaling grubunda ortalama CPU kullanımı 5 dakika boyunca %95 seviyesine çıkmıştır.

Huawei Cloud Cloud Eye, ECS ve Auto Scaling metriklerinin izlenmesini destekler. ECS metrikleri Cloud Eye üzerinden görüntülenebilir ve Auto Scaling için ayrı metrikler bulunur. Daha derin işletim sistemi ve process metrikleri için agent gerekebilir. Huawei Cloud dokümantasyonunda Cloud Eye'nin ECS metriklerini izleyebildiği, process monitoring'in ise aktif process'ler için CPU kullanımı, memory kullanımı ve açık dosyalar gibi bilgileri toplayabildiği belirtilir.

Aksiyon 1.1 — İlk Cloud Eye dashboard'unu aç

Aksiyon: Alarmın yalnızca auto-scaling grubuna mı ait olduğunu, yoksa daha geniş bir altyapı sorunundan mı kaynaklandığını doğrula.

Huawei Cloud Servisi: Cloud Eye

Console Path:

Huawei Cloud Console → Cloud Eye → Server Monitoring / Cloud Service Monitoring → Auto Scaling → prod-checkout-asg

Filtre / Görünüm:

- Region: TR-Istanbul
- Resource: prod-checkout-asg
- Time range: 03:00–03:30 UTC
- Metric: Average CPU Usage

Beklenen Kanıt:

- CPU ortalamasının 5 dakika boyunca %95 veya üzerinde olduğunu gösteren metrik.
 - Sorunun tüm ECS instance'larını mı yoksa yalnızca bir instance'ı mı etkilediği.
 - Auto Scaling'ın yeni ECS instance başlatıp başlatmadığı.
 - CPU alarmı ile sonraki brute-force ve WAF olaylarının zaman olarak örtüşüp örtüşmediği.
-

Aksiyon 1.2 — CPU'dan sonra ECS seviyesinde metrikleri kontrol et

Aksiyon: CPU artışının gerçek trafik, network baskısı, memory baskısı veya anormal host davranışından kaynaklanıp kaynaklanmadığını kontrol et.

Huawei Cloud Servisi: Cloud Eye / ECS Monitoring

Console Path:

Huawei Cloud Console → Cloud Eye → Server Monitoring → Elastic Cloud Server → prod-checkout-*

CPU'dan Sonra Kontrol Edilecek Metrikler:

1. **Network inbound/outbound rate**
Checkout servisinin anormal trafik alıp almadığını anlamak için kontrol edilir.
2. **Memory usage**
Uygulamanın memory baskısı veya swapping yaşayıp yaşamadığını görmek için kontrol edilir.
3. **Disk I/O / disk read-write rate**
Aşırı loglama, database etkileşimi veya disk darboğazı olup olmadığını anlamak için kontrol edilir.
4. **Load average / OS-level CPU metrics**
Uygulama kaynaklı baskıyı sistem/kernel kaynaklı baskıdan ayırmak için kontrol edilir.

Beklenen Kanıt:

- Network trafiği CPU ile birlikte yükseliyorsa sebep dış trafik veya saldırı trafiği olabilir.
 - Memory kullanımı da yükseliyorsa uygulama resource exhaustion yaşıyor olabilir.
 - Disk I/O sert şekilde artıyorsa aşırı loglama veya backend bağımlılığı problemi olabilir.
 - Sadece bir ECS etkileniyorsa bozuk instance, hatalı deployment veya local process problemi olabilir.
-

Aksiyon 1.3 — CPU tüketen process'i belirle

Aksiyon: Hangi process'in CPU tükettiğini belirle.

Huawei Cloud Servisi: Cloud Eye Process Monitoring / AOM / HSS

Console Path Option A:

Huawei Cloud Console → Cloud Eye → Server Monitoring → Elastic Cloud Server → Process Monitoring

Console Path Option B:

Huawei Cloud Console → Application Operations Management (AOM) → Infrastructure Monitoring → Hosts → Processes

Console Path Option C:

Huawei Cloud Console → Host Security Service (HSS) → Servers → Asset Management / Processes

Beklenen Kanıt:

- Process adı, PID, CPU kullanımı, memory kullanımı ve command path.
- Process'in checkout uygulaması mı, web server mı, runtime process mi, crypto-mining process mi yoksa şüpheli bir binary mi olduğu.
- Aynı process artışının tüm ECS instance'larında mı yoksa yalnızca tek bir host'ta mı görüldüğü.

Gerekçe:

Eğer process normal checkout uygulamasıysa ve network trafiği yüksekse CPU alarmı meşru veya kötü niyetli request yoğunluğundan kaynaklanıyor olabilir. Eğer process bilinmeyen, yeni oluşturulmuş veya şüpheli bir dizinden çalışan bir process ise host compromise ihtimali değerlendirilmelidir.

Olay 2 — 03:18:45 UTC

LTS Brute-Force Login Alarmı

Durum

LTS brute-force alarmı aşağıdaki sorguyla tetiklenir:

```
SELECT source_ip, COUNT(*) AS attempts
FROM log
WHERE request_uri = '/api/login'
AND status = 401
GROUP BY source_ip
HAVING COUNT(*) > 200
ORDER BY attempts DESC
LIMIT 5;
```

Bu sorgu, `/api/login` endpoint'ine 200'den fazla başarısız giriş denemesi yapan kaynak IP'leri tespit eder.

Huawei Cloud LTS merkezi log toplama, sorgulama, görselleştirme ve saklama sağlar. LTS, SQL benzeri log analizi ve olay inceleme için kullanılabilir.

Aksiyon 2.1 — Denenen kullanıcı adlarını belirle

Aksiyon: Saldırgan kaynak IP'den, denenen kullanıcı adlarına doğru pivot yap.

Huawei Cloud Servisi: Log Tank Service / LTS

Console Path:

Huawei Cloud Console → Log Tank Service (LTS) → Log Management → Log Group: prod-checkout → Log Stream: application-access → SQL Query

LTS SQL Query 1 — Saldırgan IP'lere göre denenen kullanıcı adları

```
SELECT username,
       source_ip,
       COUNT(*) AS failed_attempts
FROM log
WHERE request_uri = '/api/login'
AND status = 401
AND source_ip IN (
  SELECT source_ip
  FROM log
  WHERE request_uri = '/api/login'
  AND status = 401)
```

```
GROUP BY source_ip
HAVING COUNT(*) > 200
)
GROUP BY username, source_ip
ORDER BY failed_attempts DESC
LIMIT 50;
```

Beklenen Kanıt:

- Brute-force kaynak IP'leri tarafından hedeflenen kullanıcı adları.
- Saldırının çok sayıda kullanıcıya yönelik password spraying mi yoksa az sayıda hesaba odaklanan brute force mu olduğu.
- [admin](#), [support](#), [merchant-admin](#) veya çalışan e-postaları gibi yüksek riskli hesaplar.

Aksiyon 2.2 — Brute-force denemelerinden başarılı olan var mı kontrol et

Aksiyon: Aynı saldırgan IP'lerin son 30 dakika içinde [/api/login](#) üzerinde HTTP 200 cevabı alıp almadığını belirle.

Huawei Cloud Servisi: LTS

Console Path:

[Huawei Cloud Console](#) → [LTS](#) → [Log Management](#) → [prod-checkout](#) → [application-access](#) → [SQL Query](#)

LTS SQL Query 2 — Brute-force kaynak IP'lerinden başarılı girişler

```
SELECT source_ip,
       username,
       COUNT(*) AS successful_logins,
       MIN(timestamp) AS first_success,
       MAX(timestamp) AS last_success
FROM   log
WHERE  request_uri = '/api/login'
AND    status = 200
AND    timestamp >= CURRENT_TIMESTAMP - INTERVAL '30' MINUTE
AND    source_ip IN (
  SELECT source_ip
  FROM   log
  WHERE  request_uri = '/api/login'
  AND    status = 401
  AND    timestamp >= CURRENT_TIMESTAMP - INTERVAL '30' MINUTE
```

```
GROUP BY source_ip
HAVING COUNT(*) > 200
)
GROUP BY source_ip, username
ORDER BY successful_logins DESC;
```

Beklenen Kanıt:

- Hiç satır dönmezse brute-force denemeleri ilgili zaman aralığında başarılı girişe dönüşmemiştir.
 - Satır dönerse listelenen kullanıcı adları compromise olmuş olabilir; hesaplar kilitlenmeli, parola sıfırlanmalı ve login sonrası aktiviteleri incelenmelidir.
 - `first_success` timestamp değeri olay zaman çizelgesi için kritik bir işarettir.
-

Aksiyon 2.3 — Trafik paternini zaman içinde doğrula

Aksiyon: Saldırının hâlâ aktif olup olmadığını ve CPU artışıyla zaman olarak örtüşüp örtüşmediğini belirle.

Huawei Cloud Servisi: LTS

Console Path:

Huawei Cloud Console → LTS → Log Management → `prod-checkout` → `application-access` → SQL Query

LTS SQL Query 3 — Zaman içinde başarısız login denemeleri

```
SELECT DATE_TRUNC('minute', timestamp) AS minute_bucket,
       source_ip,
       COUNT(*) AS failed_attempts
FROM   log
WHERE  request_uri = '/api/login'
      AND status = 401
      AND timestamp BETWEEN TIMESTAMP '03:00:00' AND TIMESTAMP '04:00:00'
GROUP BY DATE_TRUNC('minute', timestamp), source_ip
ORDER BY minute_bucket ASC, failed_attempts DESC;
```

Beklenen Kanıt:

- Dakika bazında saldırı oranı.
- Brute-force aktivitesinin CPU alarmından önce mi, alarm sırasında mı yoksa sonra mı başladığı.
- IP engellendiğinde CPU baskısının azalıp azalmadığı.

Aksiyon 2.4 — Saldırgan IP'yi perimeter seviyesinde engelle

Aksiyon: Saldırgan IP'nin checkout servisine ulaşmasını engelle.

Huawei Cloud Servisi: WAF veya SecMaster'ın WAF/CFW/VPC/IAM ile entegre one-click blocking özelliği

Console Path Option A — WAF:

Huawei Cloud Console → Web Application Firewall → Policies → Blacklist and Whitelist → Add Rule → Block source_ip

Console Path Option B — SecMaster:

Huawei Cloud Console → SecMaster → Workspaces → Alerts / Incidents → Alert Detail → One-Click Blocking

Huawei Cloud WAF, belirli IP adreslerinden veya IP aralıklarından gelen istekleri engellemek veya izin vermek için blacklist ve whitelist kurallarını destekler. SecMaster da belirli IP, IP aralığı veya IAM kullanıcılarını blacklist'e alarak CFW, WAF, VPC ve IAM üzerinden istekleri engelleme yaklaşımını destekleyebilir.

Beklenen Kanıt:

- Saldırgan IP'ler için WAF blacklist kuralı oluşturulmuş olması.
- LTS üzerinde HTTP 401 denemelerinde düşüş.
- Brute-force CPU yüküne katkı sağladıysa CPU veya network trafiğinde düşüş.
- Bloklama kuralını kimin eklediğini gösteren CTS değişiklik kaydı.

Olay 3 — 03:32:11 UTC

SecMaster Alert: WAF Tarafından Engellenen SQL Injection Denemesi

Durum

SecMaster alert üretir:

"Known malicious IP 198.51.100.77 adresinden confirmed SQL injection attempt — WAF tarafından engellendi, kaynak IP threat intelligence feed ile ilişkilendirildi."

Huawei Cloud SecMaster güvenlik servislerinden gelen alert'leri toplar, sinyalleri ilişkilendirir ve alert'leri incident hâline getirebilir veya mevcut incident'lerle bağlayabilir. Alert detay sayfası; alert adı, türü, severity seviyesi ve inceleme detaylarını gösterir.

Aksiyon 3.1 — Tam incident detail ve correlated signals ekranını aç

Aksiyon: Alert, korelasyon ve incident bağlamını incele.

Huawei Cloud Servisi: SecMaster

Console Path:

Huawei Cloud Console → SecMaster → Workspaces → Security Operations → Alerts / Incidents → Search source IP 198.51.100.77 → Alert Detail / Incident Detail

Beklenen Kanıt:

- Alert name: confirmed SQL injection attempt.
 - Source IP: 198.51.100.77.
 - Destination domain, URI, method ve request ID.
 - WAF action: blocked.
 - Threat intelligence correlation: known malicious IP.
 - Severity ve confidence.
 - Related alerts veya correlated events.
 - Saldırı denemesinin zaman çizelgesi.
-

Aksiyon 3.2 — Request application loglarında görünür mü belirle

Soru: WAF request'i engellediyse application loglarında görünür mü?

Cevap:

Genellikle hayır. WAF isteği edge seviyesinde, ELB/ECS'ye iletmeden önce engelliyorsa uygulama bu request'i hiç almaz. Bu nedenle malicious SQL injection payload'u application access log içinde görünmeyebilir. Ancak istek WAF loglarında, SecMaster alert detayında ve WAF logları LTS'ye aktarılıyorsa LTS üzerinde görünebilir.

Beklenen Kanıt:

- Blocked request'i gösteren WAF log kaydı.
- Aynı request ID veya payload için ECS application loglarında eşleşme olmaması.

- SecMaster incident correlation kaydıyla WAF'ın isteği uygulamaya ulaşmadan engellediğinin gösterilmesi.
-

Aksiyon 3.3 — Regulator incident report için kanıt toplama

Kanıt 1 — WAF Block Log

- **Kaynak:** LTS'ye aktarılan WAF logları.
- **Saklama yeri:** `OBS evidence bucket /incident-YYYYMMDD/waf/`
- **Amaç:** SQL injection denemesinin uygulamaya ulaşmadan engellendiğini kanıtlar.

Kanıt 2 — SecMaster Incident Detail

- **Kaynak:** SecMaster alert/incident export.
- **Saklama yeri:** `OBS evidence bucket /incident-YYYYMMDD/secmaster/`
- **Amaç:** Threat intelligence korelasyonunu ve incident severity seviyesini gösterir.

Kanıt 3 — CTS Change and Response Trail

- **Kaynak:** WAF/SecMaster response action'ları için CTS trace kayıtları.
- **Saklama yeri:** `OBS evidence bucket /incident-YYYYMMDD/cts/`
- **Amaç:** Alert'i kimin incelediğini, bloklayıcı kuralını kimin oluşturduğunu ve response action'ların ne zaman yapıldığını gösterir.

CTS, kullanıcıların cloud servis kaynakları üzerinde gerçekleştirdiği oluşturma, değiştirme ve silme gibi operation detaylarını kaydeder. CTS trace'leri uzun süreli saklama için OBS'ye aktarılabilir.

Olay 4 — 04:47:53 UTC

CTS Key Event: **contractor.bilal** Tarafından OBS Bucket Silinmesi

Durum

CTS key-event notification gönderir:

- IAM user: **contractor.bilal**
- Action: **acme-customer-data-backups** adlı OBS bucket'ı silindi
- Source IP: **45.142.x.x**

- Source IP, kurumsal VPN egress aralığıyla eşleşmiyor.

Bu en ciddi olaydır çünkü credential compromise veya kötü niyetli insider activity gösterebilir ve backup bütünlüğünü doğrudan etkiler.

Aksiyon 4.1 — CTS field'larını kanıt olarak çıkar

Aksiyon: CTS trace JSON içinden temel alanları çıkar.

Huawei Cloud Servisi: Cloud Trace Service / CTS

Console Path:

Huawei Cloud Console → Cloud Trace Service → Trace List → Search
deleteBucket / OBS / contractor.bilal

CTS trace yapısı, CTS konsolunda görüntülenen temel alanlardan oluşur. CTS trace'leri cloud service resource operation kayıtlarını tutar ve hangi işlemi kimin ne zaman yaptığını belirlemek için kullanılır.

Kanıt İçin Çıkarılacak 5 CTS JSON Field:

1. `user`
2. `user_name`
3. `source_ip`
4. `trace_name`
5. `event_time`

Ek olarak faydalı alanlar:

6. `trace_type`
7. `service_type`
8. `resource_type`
9. `resource_name`
10. `request`
11. `response`
12. `trace_id`

Beklenen Kanıt:

- `user_name` = `contractor.bilal`
- `source_ip` = `45.142.x.x`
- `trace_name` = `deleteBucket` veya eşdeğer OBS bucket deletion operation
- `resource_name` = `acme-customer-data-backups`
- `event_time` = `04:47:53 UTC`

- `trace_type = ConsoleAction` veya `ApiCall`
-

Aksiyon 4.2 — `contractor.bilal` kullanıcısının son 24 saatte yaptığı tüm işlemler için CTS Trace List filtre seti

Aksiyon: `contractor.bilal` kullanıcısının son 24 saatte yaptığı tüm işlemleri bul.

Huawei Cloud Servisi: CTS

Console Path:

Huawei Cloud Console → Cloud Trace Service → Trace List

Kesin Filtre Seti:

- **Time Range:** Last 24 hours
- **Trace Source / Service Type:** Önce tüm servisler; sonra gerekirse `OBS`, `IAM`, `ECS`, `VPC`, `WAF`, `KMS` olarak daralt
- **User:** `contractor.bilal`
- **Trace Type:** `ConsoleAction` ve `ApiCall`
- **Resource Type:** Önce tüm resource type'lar; sonra `bucket`, `object`, `agency`, `user`, `policy`, `access key`
- **Trace Name:** Tam activity review için boş bırak; sonra belirli action'ları ara:
 - `deleteBucket`
 - `deleteObject`
 - `putBucketPolicy`
 - `deleteBucketPolicy`
 - `createAccessKey`
 - `updateLoginProfile`
 - `createAgency`
 - `putObject`
 - `getObject`
 - `listBucket`
- **Resource Name:** Silinen bucket'a odaklanırken `acme-customer-data-backups`

Beklenen Kanıt:

- Kullanıcının yalnızca bucket'ı mı sildiği, yoksa önce reconnaissance yapıp yapmadığı.
- Access key oluşturulup oluşturulmadığı veya kullanılıp kullanılmadığı.
- Deletion öncesinde bucket policy, IAM policy veya agency permission değişikliği olup olmadığı.

- Başka hassas kaynaklara erişilip erişilmediği.
 - İşlemlerin aynı şüpheli IP'den yapılıp yapılmadığı.
-

Aksiyon 4.3 — İlk IAM savunma aksiyonu

Aksiyon: Kimliği kanıtı yok etmeden kontrol altına al.

Huawei Cloud Servisi: IAM

Console Path:

Huawei Cloud Console → Identity and Access Management → Users → `contractor.bilal`

İlk Savunma Aksiyonu:

Kullanıcının erişimini devre dışı bırak ve aktif credential'ları revoke et, ancak kullanıcıyı silme.

Spesifik Adımlar:

1. `contractor.bilal` için console login'i devre dışı bırak.
2. Access key'leri disable et veya sil.
3. Kullanıcıyı yüksek riskli gruplardan çıkar.
4. Varsa temporary credential'ları revoke et.
5. IAM user object, group membership, policy ve CTS trace kayıtlarını kanıt olarak koru.

Gerekçe:

Kullanıcıyı hemen silmek context'i yok edebilir ve forensic timeline oluşturmaya zorlaştırabilir. Öncelik, containment ve evidence preservation olmalıdır.

Aksiyon 4.4 — OBS deletion geri alınabilir mi belirle

Soru: Veri gerçekten gitti mi?

Cevap:

Bu, OBS protection ayarlarına bağlıdır. OBS versioning devre dışıysa ve object'ler manuel olarak silindiye, silinen veya üzerine yazılan veriler geri getirilemeyebilir. Versioning silinmeden önce aktifse, önceki object version'ları kurtarılabilir. WORM retention aktifse, retention süresi boyunca korunan object version'ları silinemez.

Recovery Workflow:

1. OBS bucket versioning açık mı kontrol et.
2. WORM retention açık mı kontrol et.
3. Otomatik deletion için lifecycle rule var mı kontrol et.

4. Cross-region replication veya backup copy var mı kontrol et.
5. Versioning aktifse silinen object version'larını restore et.
6. WORM retention aktifse deletion'ın engellenip engellenmediğini veya yalnızca delete marker oluşup oluşmadığını doğrula.
7. Versioning, WORM veya backup yoksa bucket deletion'ı kalıcı veri kaybı olarak değerlendir ve derhal escalate et.

Console Path:

Huawei Cloud Console → Object Storage Service → Bucket List → acme-customer-data-backups → Objects / Versions / WORM / Lifecycle Rules

Beklenen Kanıt:

- Versioning durumu.
 - WORM retention durumu.
 - Silinen object version'ları veya delete marker'lar.
 - Lifecycle rule geçmişi.
 - Replication veya backup durumu.
 - Nihai recovery kararı.
-

LTS SQL Query Appendix

Query 1 — Brute-force ile hedeflenen kullanıcı adlarını belirle

```
SELECT username,  
       source_ip,  
       COUNT(*) AS failed_attempts  
FROM   log  
WHERE  request_uri = '/api/login'  
AND    status = 401  
AND    source_ip IN (  
    SELECT source_ip  
    FROM   log  
    WHERE  request_uri = '/api/login'  
    AND    status = 401  
    GROUP BY source_ip  
    HAVING COUNT(*) > 200  
)  
GROUP BY username, source_ip  
ORDER BY failed_attempts DESC  
LIMIT 50;
```

Query 2 — Saldırgan IP'lerden başarılı login var mı kontrol et

```
SELECT source_ip,
       username,
       COUNT(*) AS successful_logins,
       MIN(timestamp) AS first_success,
       MAX(timestamp) AS last_success
FROM   log
WHERE  request_uri = '/api/login'
      AND status = 200
      AND timestamp >= CURRENT_TIMESTAMP - INTERVAL '30' MINUTE
      AND source_ip IN (
        SELECT source_ip
        FROM   log
        WHERE  request_uri = '/api/login'
              AND status = 401
              AND timestamp >= CURRENT_TIMESTAMP - INTERVAL '30' MINUTE
        GROUP BY source_ip
        HAVING COUNT(*) > 200
      )
GROUP BY source_ip, username
ORDER BY successful_logins DESC;
```

Query 3 — Zaman içinde başarısız login denemeleri

```
SELECT DATE_TRUNC('minute', timestamp) AS minute_bucket,
       source_ip,
       COUNT(*) AS failed_attempts
FROM   log
WHERE  request_uri = '/api/login'
      AND status = 401
      AND timestamp BETWEEN TIMESTAMP '03:00:00' AND TIMESTAMP '04:00:00'
GROUP BY DATE_TRUNC('minute', timestamp), source_ip
ORDER BY minute_bucket ASC, failed_attempts DESC;
```

Query 4 — Compromise olmuş olabilecek kullanıcıların login sonrası aktiviteleri

```
SELECT username,
       source_ip,
       request_uri,
       status,
       COUNT(*) AS requests
FROM   log
```

```
WHERE username IN (  
    SELECT username  
    FROM log  
    WHERE request_uri = '/api/login'  
    AND status = 200  
    AND timestamp >= CURRENT_TIMESTAMP - INTERVAL '30' MINUTE  
)  
AND timestamp >= CURRENT_TIMESTAMP - INTERVAL '30' MINUTE  
GROUP BY username, source_ip, request_uri, status  
ORDER BY requests DESC  
LIMIT 100;
```

Not: `username`, `timestamp`, `request_uri`, `status` ve `source_ip` gibi field adları, Acme Retail'in LTS log stream'indeki gerçek structured parsing field adlarına göre uyarlanmalıdır.

Synthesis

En tehlikeli olay hangisiydi ve neden?

En tehlikeli olay Event 4'tür: `contractor.bilal` kullanıcısının kurumsal olmayan bir IP adresinden OBS backup bucket'ını silmesi. CPU artışı, brute-force login kampanyası ve SQL injection denemesi operasyonel olarak acil ve gürültülü olaylardır; ancak Event 4 doğrudan backup bütünlüğünü etkiler ve credential compromise veya malicious insider activity gösterebilir. Silinen bir backup bucket, özellikle versioning, WORM retention veya replication aktif değilse güvenlik olayını iş sürekliliği ve regülasyon krizine dönüştürebilir.

CEO Briefing — Üç Cümle

Gece boyunca checkout servisinde yüksek CPU yükü, brute-force login kampanyası ve WAF tarafından engellenen bir SQL injection denemesi tespit ettik.

En ciddi olay, `acme-customer-data-backups` OBS bucket'ının kurumsal olmayan bir IP adresinden bir IAM kullanıcısı tarafından silinmesidir; bu durum credential compromise ve potansiyel backup kaybı göstergesi olabilir.

Kimliği kontrol altına aldık, CTS, LTS, WAF, SecMaster ve OBS kanıtlarını koruyoruz ve recovery'nin OBS versioning, WORM retention veya backup replication üzerinden mümkün olup olmadığını doğruluyoruz.

Event 4'ü tamamen hangi Huawei Cloud özelliği önleyebilirdi?

En güçlü önleyici kontrol, contractor hesapları için OBS bucket deletion yetkisini açıkça reddeden least-privilege IAM policy olurdu. Bu kontrol MFA ve source-IP condition ile birleştirilmeliydi.

Spesifik kontrol şöyle yazılabilir:

IAM policy: **obs:DeleteBucket** ve destructive OBS action'ları; yalnızca MFA ile doğrulanmış, kurumsal VPN egress IP aralığından bağlanan, onaylı break-glass administrator rolü dışındaki tüm principal'lar için deny edilmelidir.

Ek önleyici kontroller:

- Backup object'leri için OBS WORM retention.
- Backup bucket'ları için OBS versioning.
- Destructive action'lar için CTS key event notification.
- Şüpheli IAM kullanıcılarını otomatik devre dışı bırakacak SecMaster playbook.
- Separation of duties: Contractor hesaplarının production backup bucket silme yetkisi olmamalıdır.

Opsiyonel Stretch Goal — SecMaster SOAR Playbook YAML

playbook_name: acme-retail-cloud-incident-response

description: >

Huawei Cloud TR-Istanbul üzerinde brute-force login, WAF SQL injection ve şüpheli OBS bucket deletion olayları için SOAR tarzı response playbook.

trigger:

source: SecMaster

conditions:

- alert_type in ["Brute Force", "SQL Injection", "Suspicious IAM Activity"]
- severity in ["High", "Critical"]

steps:

- name: enrich_alert
- action: query_context
- services:
 - SecMaster

- LTS
- CTS

outputs:

- source_ip
- username
- resource_name
- trace_id
- related_alerts

- name: block_malicious_ip
- condition: source_ip is not null

action: block_ip

target_services:

- WAF
- CFW

parameters:

ip: "{{ source_ip }}"

duration: "24h"

reason: "Automated block from SecMaster incident"

- name: contain_suspicious_identity
- condition: username contains "contractor" or alert_type == "Suspicious IAM Activity"

action: disable_identity

target_service: IAM

parameters:

user: "{{ username }}"

preserve_user_object: true

disable_access_keys: true

disable_console_login: true

- name: snapshot_evidence

action: export_evidence

target_service: OBS

parameters:

bucket: "acme-security-evidence"

path: "incidents/{{ incident_id }}/"

include:

- SecMaster incident detail
- CTS traces
- LTS query results
- WAF logs
- OBS bucket configuration

- name: notify_on_call

action: send_notification

target_service: SMN

parameters:

topic: "security-on-call"

message: "Critical cloud security incident {{ incident_id }} requires review."

- name: open_ticket

action: webhook

parameters:

url: "https://tickets.acme.example/api/incidents"

method: POST

payload:

incident_id: "{{ incident_id }}"

severity: "{{ severity }}"

summary: "{{ alert_name }}"

evidence_path: "obs://acme-security-evidence/incidents/{{ incident_id }}/"